Informe Profesional de Pentesting

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información — Actividad A08

---

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Santiago Berardini
DNI	44246721
Username TryHackMe	santiagoberardini
Email institucional	santiagoberardini@gmail.com
Sala de elección (Nivel 2)	Vulnversity
Branch en GitHub	berardini-santiago
Fecha de inicio	2026-10-8
Fecha de cierre	*2026-10-15*

---

2. Pre-pentesting

Alcance del trabajo

El alcance abarca únicamente los entornos de laboratorio de TryHackMe asignados en la guía de cátedra: las salas Pentesting Fundamentals y Basic Pentesting (núcleo obligatorio) y Vulnversity (sala de elección, Nivel 2). Quedan excluidos cualquier sistema fuera de estos laboratorios, incluyendo sistemas de producción de INSECUR S.A. o de terceros.

Reglas de Enfrentamiento (ROE)

Horarios: sin restricción horaria específica más allá del tiempo de disponibilidad de las máquinas de TryHackMe. Técnicas prohibidas: cualquier técnica contra sistemas no autorizados fuera del laboratorio, y ataques de denegación de servicio (DoS) sobre la

infraestructura de TryHackMe. Límites de tráfico: tráfico limitado al necesario para herramientas de reconocimiento/escaneo (nmap, gobuster, hydra, john), evitando escaneos agresivos que degraden el servicio. Notificación ante incidentes: cualquier comportamiento anómalo de la máquina objetivo se reporta de inmediato al docente de la cátedra.

Autorización

Se declara contar con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para realizar las actividades de pentesting sobre los entornos de laboratorio de TryHackMe indicados en la Guía + Plantilla A08, en el marco de la Actividad A08 — Hacking Ético.

Metodología utilizada

Se siguió un enfoque alineado a NIST SP 800-115, por ser el marco sugerido por la guía de cátedra y adaptarse al formato de las salas trabajadas: Reconocimiento, Escaneo, Enumeración, Explotación y Postexplotación, documentando cada hallazgo a medida que se avanzaba.

---

3. Durante: Hallazgos por fase

Completar una fila por cada hallazgo relevante. Duplicar la tabla si se necesitan más filas.

Campo	Valor
ID del hallazgo	H-01
Fase	Explotación
Descripción	Se logró acceso remoto al servidor (10.64.148.151) mediante ataque de fuerza bruta contra el servicio SSH, utilizando Hydra con el diccionario rockyou.txt. Se obtuvieron credenciales válidas para el usuario "jan" (password: ver hash en Anexo C), permitiendo el inicio de sesión vía SSH. Una vez dentro se verificó con whoami && uname -a && sudo -l que el sistema es Ubuntu 20.04.6 LTS (kernel 5.15.0-139-generic) y que el usuario jan no posee permisos sudo ("Sorry, user jan may not run sudo").
Componente afectado	Servicio SSH (puerto 22)

Campo	Valor
Categoría (OWASP / CWE)	CWE-307: Improper Restriction of Excessive Authentication Attempts
CVE (si aplica)	
CVSS estimado	Alto
Evidencia (captura / comando)	hydra -l jan -P rockyou.txt 10.64.148.151 ssh -t 16 -f; login SSH y salida de whoami && uname -a && sudo -l. Capturas en evidencias/explotacion/.
Herramienta utilizada	Hydra v9.7
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Políticas de contraseñas robustas, bloqueo tras N intentos fallidos (fail2ban), preferir autenticación por clave pública, limitar acceso SSH por IP/VPN mediante firewall.
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-02
Fase	Postexplotación
Descripción	Al enumerar el sistema como jan se detectó que /home/kay/.ssh era legible y que la clave privada id_rsa tenía permisos -rw-r--r-- (644), permitiendo que cualquier usuario la leyera. Se copió el archivo (scp) y se crackeó su passphrase con ssh2john + John the Ripper y rockyou.txt, obteniéndose "beeswax" (hash en Anexo C, H-02). Con la clave y su passphrase se logró acceso SSH como kay.
Componente afectado	Clave privada SSH de kay (/home/kay/.ssh/id_rsa)
Categoría (OWASP / CWE)	CWE-276: Incorrect Default Permissions
CVE (si aplica)	
CVSS estimado	Alto

Campo	Valor
Evidencia (captura / comando)	ls -la /home/kay/.ssh; scp exitoso; ssh2john + john --wordlist=rockyou.txt; login SSH como kay. Capturas en evidencias/post/.
Herramienta utilizada	scp, ssh2john, John the Ripper
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Restringir permisos de archivos sensibles (chmod 600), auditorías periódicas de permisos en /home, passphrases más robustas.
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-03
Fase	Postexplotación
Descripción	Autenticado como kay, se encontró un archivo pass.bak en su home (ilegible para jan pero accesible para kay) con una contraseña en texto plano. Al ejecutar sudo -l con esa contraseña se confirmó que kay posee privilegios completos de sudo ("(ALL : ALL) ALL"), permitiendo escalar a root mediante sudo -i.
Componente afectado	Archivo pass.bak / configuración de sudoers
Categoría (OWASP / CWE)	CWE-256: Unprotected Storage of Credentials
CVE (si aplica)	
CVSS estimado	Crítico
Evidencia (captura / comando)	cat pass.bak; sudo -l mostrando (ALL : ALL) ALL; whoami tras sudo -i confirmando root. Capturas en evidencias/post/.
Herramienta utilizada	Enumeración manual (cat, sudo -l)
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Eliminar backups con credenciales en texto plano, principio de menor privilegio en sudoers, rotación periódica de contraseñas.

Campo	Valor
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-04
Fase	Explotación
Descripción	En la sala Vulnversity se identificó un formulario de subida de archivos en /internal/index.php que bloqueaba la extensión .php pero no .phtml. Se subió una shell reversa PHP (pentestmonkey) renombrada a .phtml, obteniendo ejecución remota de comandos como el usuario www-data al navegar a /internal/uploads/shell.phtml con una sesión de netcat en escucha. Se encontró además la flag de usuario en /home/bill/user.txt.
Componente afectado	Formulario de subida de archivos (puerto 3333, Apache)
Categoría (OWASP / CWE)	CWE-434: Unrestricted Upload of File with Dangerous Type
CVE (si aplica)	
CVSS estimado	Alto
Evidencia (captura / comando)	gobuster revelando /internal/; curl de subida con extensión .phtml; conexión recibida en nc -lvnp 1234 con uid=33(www-data); cat /home/bill/user.txt. Capturas en evidencias/escaneo/ y evidencias/explotacion/.
Herramienta utilizada	Gobuster, curl, netcat, php-reverse-shell (pentestmonkey)
Impacto en la Tríada CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Validar el tipo de archivo subido por contenido real (no solo extensión), usar listas blancas estrictas de extensiones, deshabilitar la ejecución de scripts en el directorio de uploads, aislar el servicio en un contenedor o sandbox.
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-05
Fase	Postexplotación
Descripción	Como www-data se encontró el binario /bin/systemctl con el bit SUID activado, una configuración fuera de lo normal para ese binario. Se explotó creando un servicio systemd temporal que, al ejecutarse con privilegios de root (heredados del bit SUID), otorgó el bit SUID a /bin/bash, permitiendo obtener una shell de root con bash -p. Se confirmó el acceso con whoami y se obtuvo la flag final en /root/root.txt.
Componente afectado	Permisos del binario /bin/systemctl
Categoría (OWASP / CWE)	CWE-269: Improper Privilege Management
CVE (si aplica)	
CVSS estimado	Crítico
Evidencia (captura / comando)	find / -perm -4000 -type f mostrando /bin/systemctl; creación y activación del servicio malicioso; whoami devolviendo root; cat /root/root.txt. Captura en evidencias/post/root_vulnversity.png.
Herramienta utilizada	systemctl, bash (GTFOBins)
Impacto en la Tríada CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Eliminar el bit SUID de binarios que no lo requieren (systemctl no debe tenerlo), auditar periódicamente binarios SUID del sistema, aplicar principio de menor privilegio.
Riesgo residual tras aplicar	Bajo

---

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	H-03, H-05

Severidad	Cantidad	ID de hallazgos
Alto	3	H-01, H-02, H-04
Medio	0	
Bajo	0	
Total	5	

---

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. Implementar fail2ban o bloqueo de cuentas tras intentos fallidos de SSH (prioridad alta — H-01).
2. Corregir permisos de archivos sensibles (claves privadas, backups de contraseñas) a 600 y auditar periódicamente (prioridad alta — H-02 y H-03).
3. Eliminar archivos de backup con credenciales en texto plano como pass.bak (prioridad crítica — H-03).
4. Aplicar principio de menor privilegio en la configuración de sudoers (prioridad alta — H-03).
5. Reemplazar autenticación por contraseña en SSH por autenticación por clave pública únicamente (prioridad media).

Recomendaciones administrativas (políticas y procesos)

Política de contraseñas robusta y obligatoria (longitud mínima, complejidad, no reutilización). Capacitación periódica del personal en buenas prácticas de seguridad (no dejar notas con contraseñas, no reutilizar credenciales entre sistemas). Auditorías internas periódicas de permisos de archivos y configuración de sudoers. Adopción de un gestor de contraseñas/secretos (vault) para evitar backups en texto plano.

---

6. Protocolo de contingencia

Escenario de falla

La aplicación de parches de permisos o la reconfiguración de sudoers podría interrumpir temporalmente el acceso de administradores legítimos si se despliega sin pruebas previas, o un bloqueo de cuentas mal configurado (fail2ban) podría bloquear

accidentalmente a usuarios legítimos tras intentos fallidos propios.

Impacto sobre la continuidad del negocio

Si el servicio SSH queda inaccesible, el personal de INSECUR S.A. pierde la posibilidad de administrar remotamente el servidor, afectando tareas de soporte y mantenimiento durante el tiempo que dure la interrupción (estimado entre 15 minutos y 1 hora siguiendo el plan de respuesta).

Plan de respuesta

1. **Activación:** se detecta mediante monitoreo de logs de autenticación (auth.log) y alertas de fail2ban/IDS, o por reporte directo de administradores que no logran conectarse.
2. **Contención:** en los primeros 15 minutos se aísla el servicio afectado, se revisan los logs para confirmar si fue un bloqueo accidental o un ataque real, y se habilita un canal de acceso alternativo (consola local/out-of-band) para administradores.
3. **Recuperación:** se revierte (rollback) el cambio de configuración que causó la falla o se restaura desde backup de configuración, y se reinicia el servicio SSH.
4. **Comunicación:** se notifica al responsable de TI/dirección de INSECUR S.A. y a los administradores afectados; si hay impacto en clientes, se notifica también al área comercial.
5. **Post-mortem:** se registra el incidente en la bitácora de incidentes, se documenta la causa raíz y las acciones correctivas, y se actualiza este protocolo de contingencia si corresponde.

RTO y RPO estimados

- **RTO (Recovery Time Objective):** 1 hora — tiempo estimado para restaurar el servicio SSH tras una falla de configuración.
- **RPO (Recovery Point Objective):** 15 minutos — la configuración se respalda frecuentemente, por lo que la pérdida máxima de cambios aceptable es baja.

---

7. Anexos

Anexo A — Bitácora de comandos: adjuntar los archivos `bitacora/clase_XX_*.txt` en el branch.

Anexo B — Capturas de pantalla: carpeta `evidencias/` con subcarpetas por fase. Nombrar cada archivo como `<fase>_<hallazgoID>.png`.

Anexo C — Hashes de las flags obtenidas

Flag ID	Hash SHA-256
H-01	9eb6835cc95b053818b660bd9fc9f092a0b30cef89c1f0f17f469d5caa0ae61
H-02	873504f0103a88d762191a358f4aa432dbbcf8af64f19dd913d7f8f925191a08
H-03	ca026c78b0e4737391c5b0ac578fb71fd85c664fe354fd8ab67c115a264c8d54
H-04 (user flag)	d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956
H-05 (root flag)	cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante: _____ Fecha: _____